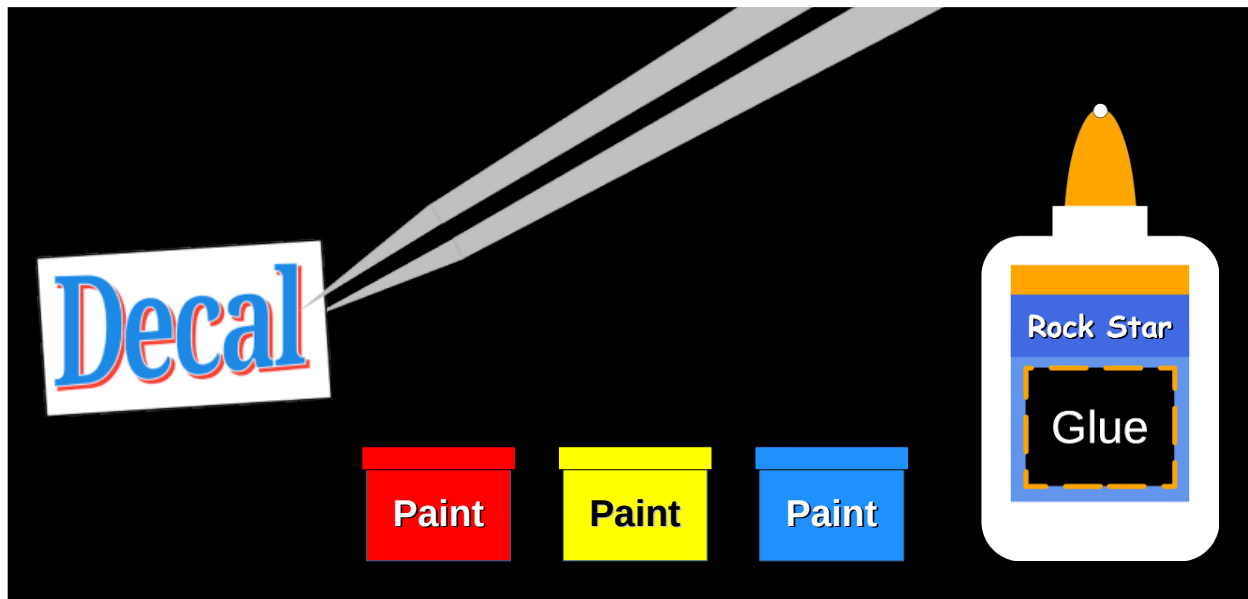


Cybersecurity Models



That Mostly Matter

About Me

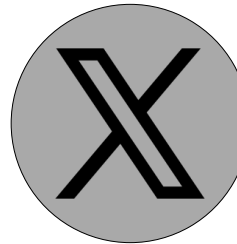
I work for a big well-known organization...



As Vice President (VP) of Computer Security and Incident Response (IR). However, I have many years of hands-on technical experience, including Digital Forensics & Incident Response (DFIR).



<https://www.linkedin.com/in/mattscheurer>



<https://x.com/c3rkah>

Where I volunteer...

I am an Official



Advocate

<https://www.hackingisnotacrime.org>



Advisory Board: Information
Technology and Cybersecurity

<https://www.mywccc.org>



Women's Security Alliance
(WomSA) Technical Mentor

<https://www.womsa.org>

Disclaimer!

Yes, I have a day job.
However...

Opinions expressed are based solely on my own independent security research and do not express or reflect the views or opinions of my employer.



Objective

The terms “Controls”, “Frameworks”, and “Models” are often used interchangeably.

While all are good, this talk is less about what I’d consider “Controls” or “Frameworks”; and focuses on what I consider Cybersecurity “Models”.

Agenda

- The classic “CIA triad”
- The “Cyber Kill Chain”
- The “Pyramid of Pain”
- Threat Modeling using “STRIDE”
- The “Diamond Model of Intrusion Analysis”



<http://slides.dfir.matt.com>

The Foundation

The CIA triad...

CIA triad



CIA triad Missing Item?

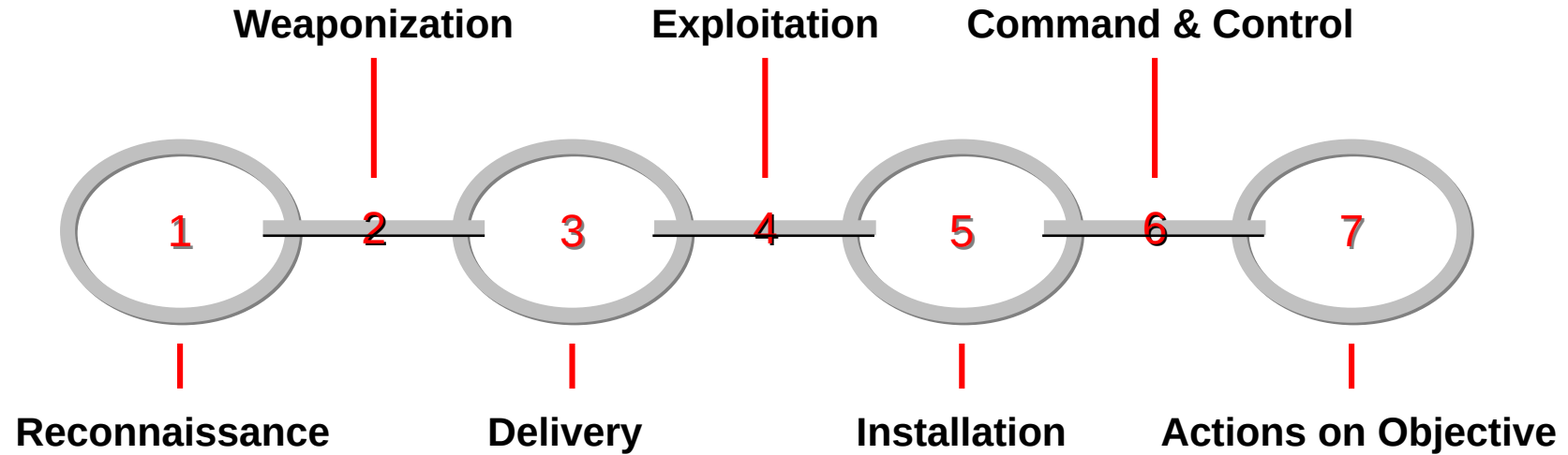
Non-Repudiation

The Stages of an Attack

The Cyber Kill Chain...

Source: [Lockhead Martin](#)

The Cyber Kill Chain

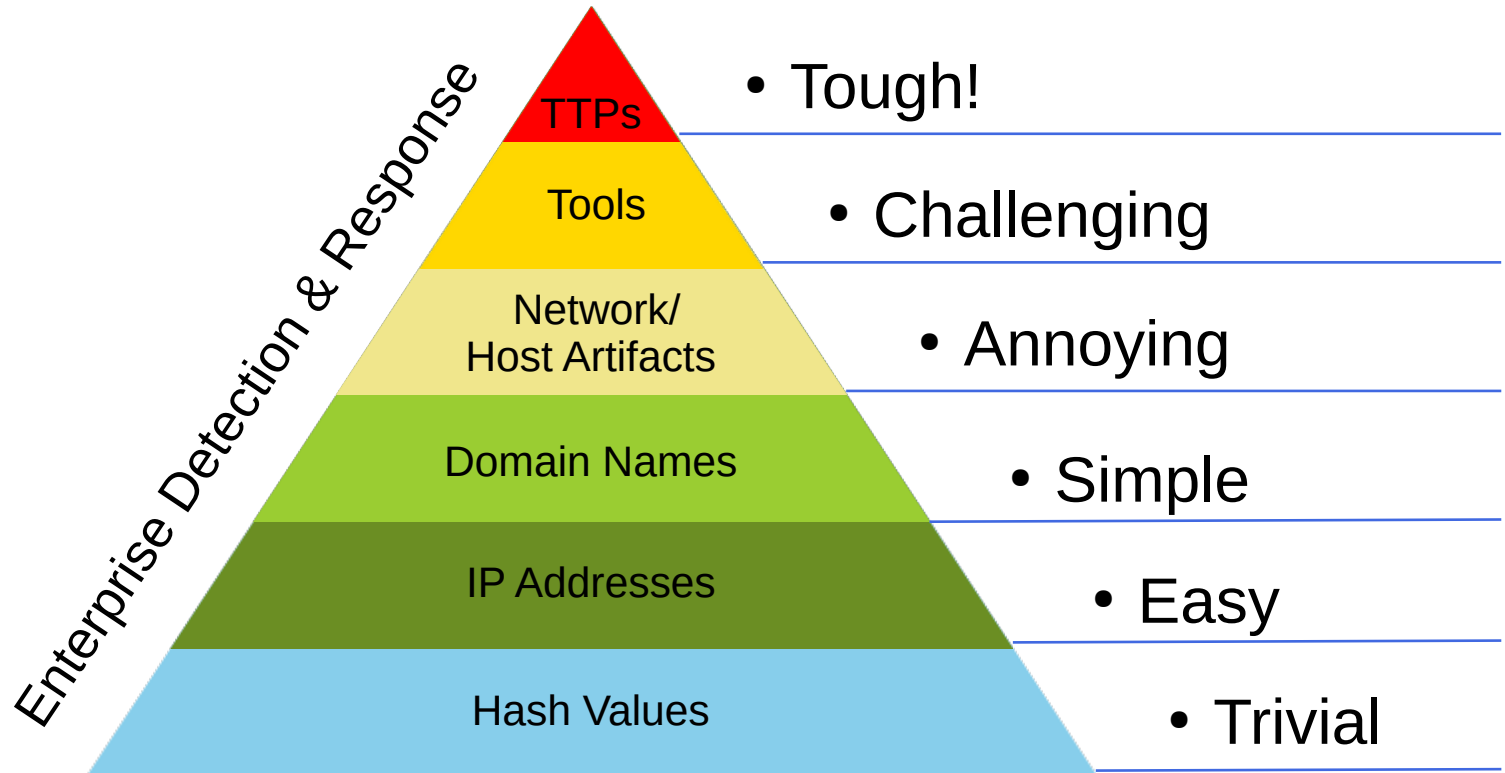


Detection Engineering

The Pyramid of Pain...

Source: [David J. Bianco](#)

The Pyramid of Pain



Threat Modeling

STRIDE (or STRIDE+)
One methodology, of many...

Source: [Microsoft](#)

The STRIDE Methodology

Spoofing

Tampering

Repudiation

Information Disclosure

Denial of Service

Elevation of Privilege

North Korea (DPRK) Examples

Reference Articles

<https://www.justice.gov/opa/pr/justice-department-announces-coordinated-nationwide-actions-combat-north-korean-remote>

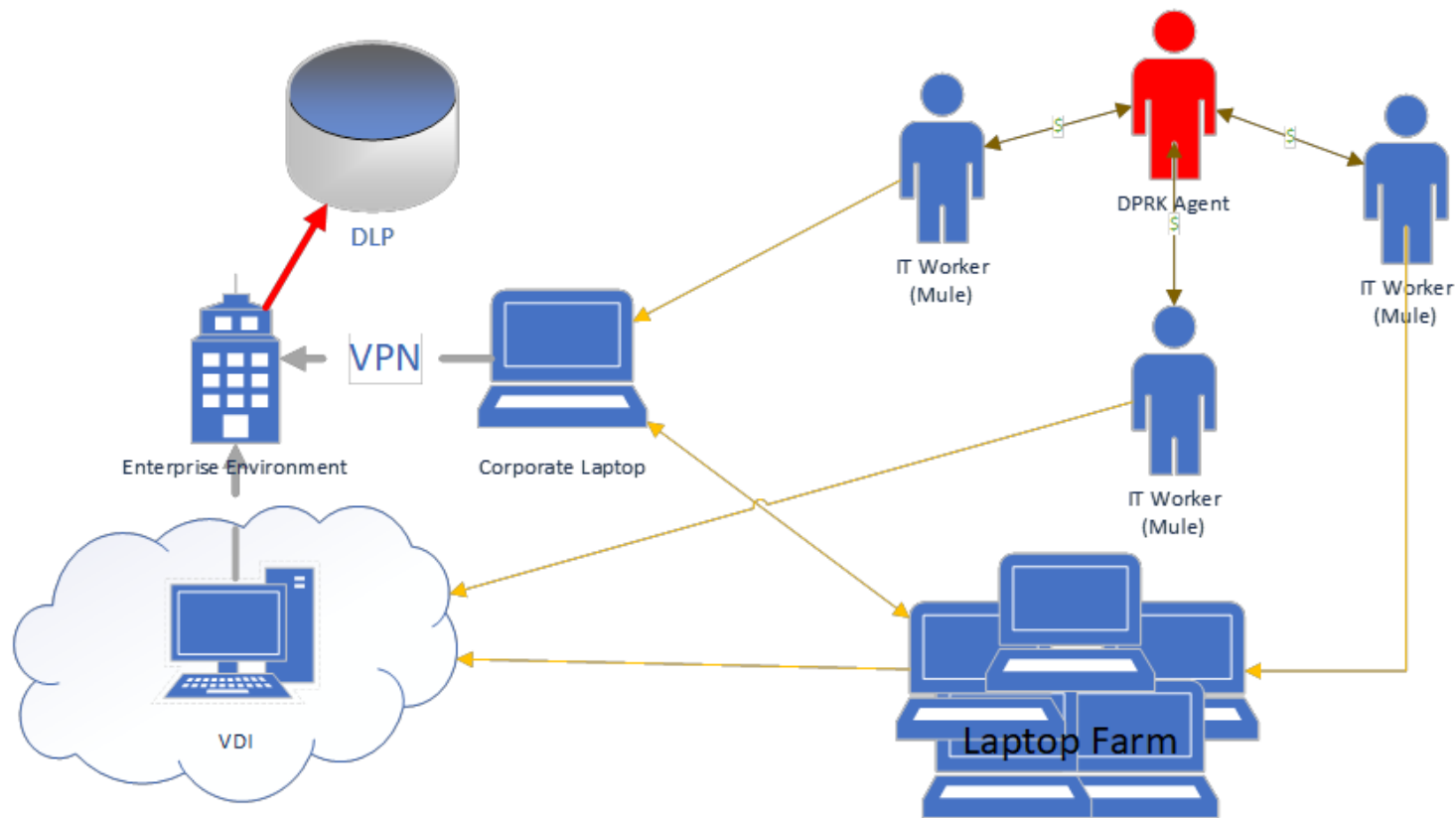
<https://home.treasury.gov/news/press-releases/sb0190>

Common Tradecraft

- Stolen Identities
- Laptop Farms
- RMM Applications
- VPNs
- Travel Routers
- KVM switches/PiKVMs

STRIDE “plus” Example

How do users, and also how does data get in and get out?



STRIDE to Risk Matrix Example

Threat	Risk Type	Likelihood	Importance	Risk Rating	Risk Score
<u>S</u> poofing	Identity	Critical	High	High	10
<u>T</u> ampering	Device/Access	Critical	High	High	10
<u>R</u> epudiation	Evidence	Critical	Critical	Critical	12
<u>I</u> nformation Disclosure	Data Leakage	Critical	Critical	High	11
<u>D</u> enial of Service	Disruption	Low	Low	Low	3
<u>E</u> scalation of Privilege	Lateral Movement	Critical	High	Medium	9

Ratings: Critical (4), High (3), Medium (2) Low (1)

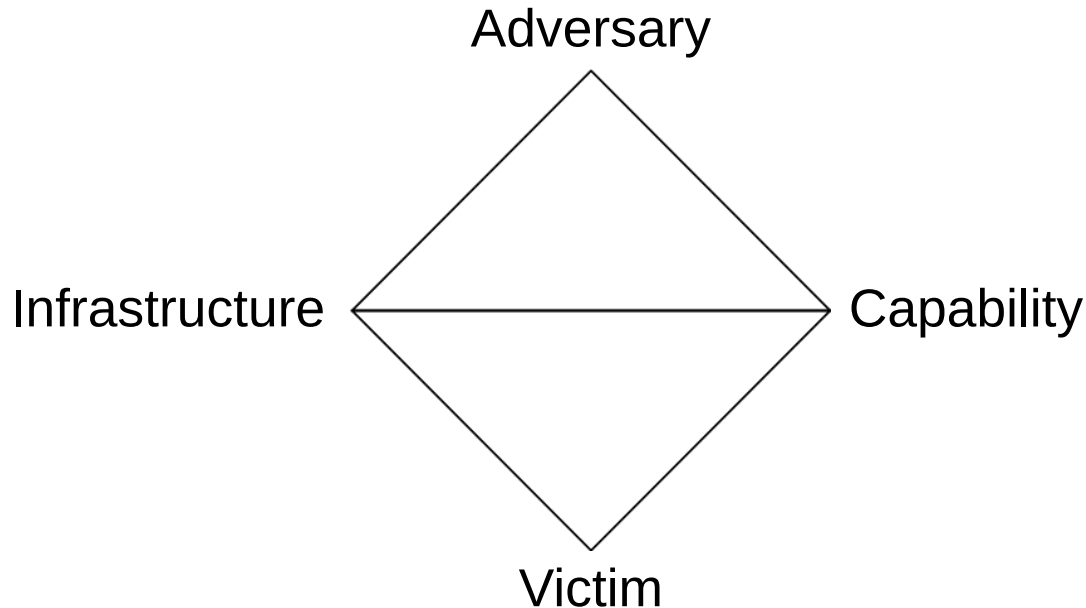
Intrusion Analysis

The Diamond Model...

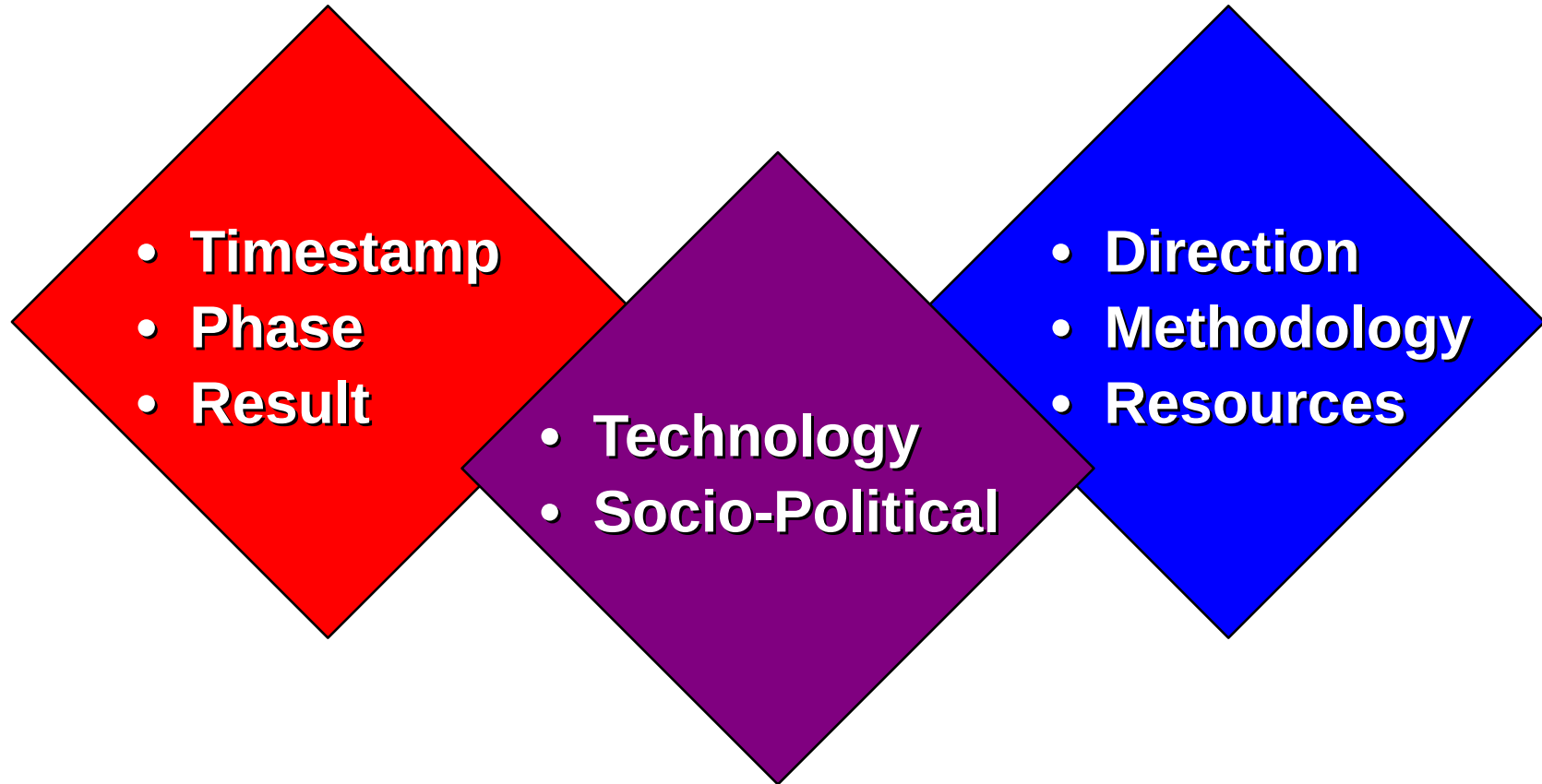
Source: *S. Caltagirone, A. Pendergast, & C. Betz*

The Diamond Model

of Intrusion Analysis:



Diamond Model: Meta-Features



Diamond Model Examples

<https://thedfirreport.com/>

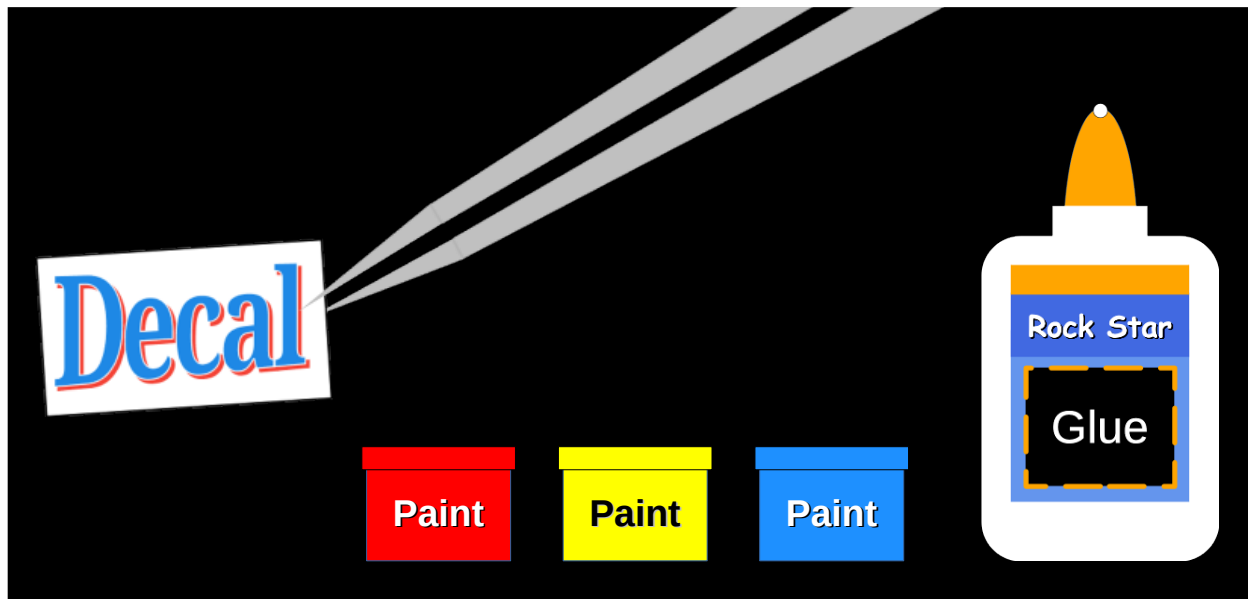
Questions



Who?
What?
When?
Where?
Why?
How?



Cybersecurity Models



That Mostly Matter